

Data Security Techniques and Defence-in-Depth Strategy

Data security is central to your work as a data engineer. In this train, we show common principles in data security.

Learning Objectives

By the end of this train, you should be able to:

- Understand why data security is required.
- Describe the security practices for working with big data.
- Understand how a defence-in-depth approach can be used to secure applications.

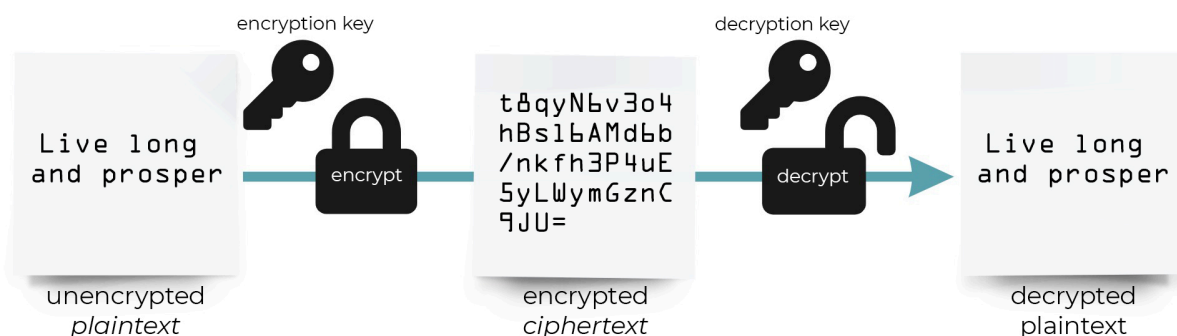
1. Security Practices for Working with Big Data

Several practices can improve and increase data security, such as **encryption**, **erasure**, **masking**, and **resiliency**. Although no specific one is the ultimate solution, in combination, they can significantly improve security and reduce overall risk in your organisation.

1.1 Encryption

Simply put, **encryption** makes data secure and exchanges of data safer by making it **only understandable by those authorised to read it**.

Data encryption **transforms human-readable text characters (*plaintext*) into an unreadable format (*ciphertext*) through mathematical algorithms**.



An illustration of general encryption.

Encryption Algorithms

There are two types of encryption algorithms: symmetric and asymmetric.

Symmetric Encryption



Symmetric encryption utilises a single shared private key. The sender and receiver use the same secret key for both encryption and decryption.

An illustration of symmetric encryption using the AES 128 algorithm.

Use cases:

- The banking sector: bank cards and other PII required for financial transactions.
- Data storage: data at-rest stored on a device.

Asymmetric Encryption



Asymmetric encryption (also known as **public key encryption**) utilises two separate keys — a public key for encryption and a private key for decryption.



An illustration of asymmetric encryption.

Use cases:

- Digital signatures: detect unauthorised modifications and authenticate identity.
- Public key infrastructure (PKI): manages digital certificates.
- Blockchain: confirms identities and authorises cryptocurrency transactions.

Encryption at Various Data States

Data at-rest Encryption



The main purpose of encrypting data at-rest is to provide countermeasures to possible breaches of stored data, making it unintelligible to unauthorised parties.

Data in-transit Encryption



Encryption of data in-transit secures data being moved between a sender and a receiver. Even if both parties' data is encrypted at-rest, data in-transit may be open to breaches such as eavesdropping.

Data in-transit and at-rest encryption.

End-to-end Encryption (E2EE)



Only the sender and intended receiver(s) can access the data. E2EE relies on a public-private key pair and encryption occurs at the device level.

End-to-end encryption (E2EE).

Cloud Encryption

Cloud providers offer data encryption services similar to on-premise solutions such as HTTPS and TLS. Key considerations include: what data needs encrypting, when it should be encrypted (client-side vs server-side), and who manages the encryption keys.

Note: Encryption doesn't prevent unauthorised access to data but it does deny access to intelligible data.

1.2 Erasure

Data erasure is a software-based method of securely **overwriting data with zeros and ones** to have the data in an **unrecoverable state**.

Overwriting:

Data can be erased by writing new data over the old. Overwriting involves writing a pattern of binary data over the original data using a random pattern or set algorithm.

Cryptographic Erasure (CE):

Cryptographic Erasure entails **discarding a cryptographic key of encrypted data to permanently delete the data**. The encryption key is destroyed, rendering the data permanently inaccessible.

The Right to Erasure:

Right to erasure and GDPR



The right to erasure applies in the GDPR if:

- The data is no longer necessary for the purpose it was originally obtained for.
- The individual withdraws their consent.
- Personal data are processed for direct marketing and the individual objects to it.
- The data are unlawfully or illegally processed.

Similarly, **POPIA** specifies that an individual has the right to request personal data be corrected, deleted, or erased if the data are excessive, irrelevant, or inaccurate.

1.3 Masking

Data masking involves **replacing sensitive data with dummy data while keeping the structural properties of the original data**.

Data Masking Types

Static Data Masking (SDM)



A copy of the data is created in a separate environment where it's masked. Applied so that development and testing can be run on the data without revealing actual sensitive data.

On-the-fly Data Masking



Applied while sensitive data are being transferred from production to the target location. Subsets of the sensitive data are stored and masked in a development environment before transfer.

Dynamic Data Masking (DDM)



Sensitive data are streamed from production to another environment where they're masked without being stored. Only applicable to read-only applications.

Data Masking Techniques

Data masking through encryption, scrambling, substitution, nulling out, and value variance.

Data Scrambling



Entails jumbling or scrambling the original data so that it's incomprehensible in its masked state.

Data Substitution



Entire data fields are replaced with values that mimic the original data. All instances of a specific data point are changed to the same new data point.

Data Shuffling



Uses the column of the original data to make substitutions within that column — switching values between records.

Nulling Out



A null value is applied to entire data columns to ensure unauthorised persons don't see the sensitive data.

Value Variance



Replaces sensitive data values with a function such as the variance of a value or the difference between values. Often applied to mask financial information.

Data Masking Best Practices

1. Identify the scope



Understand which organisational data are sensitive, how it's gathered, where it's stored, who should be authorised to access it, and which applications use it.

2. Define the set of masking techniques and their referential integrity



A set of masking techniques, rather than a single technique, is required. Masking techniques should be synchronized across all implementations.

3. Secure the masking techniques



The masking algorithms, dummy datasets, and dictionaries used to generate masks need to be protected and only accessible to authorised users.

1.4 Resiliency

Data resiliency is all about keeping data, systems, and applications up and running despite a security attack, data breach, or system failure.

Data Resiliency Techniques

Copies



Data are copied or replicated so that it can be recovered in the event of data loss, including **backups**, **mirroring**, and **cloning**.

Snapshots



Snapshots are metadata copies taken incrementally. They show where data were located at specific points in time. Snapshots enable fast data recovery while being space efficient. Most cloud providers provide point-in-time snapshots for a defined period.

Data Resiliency Technologies

Logical Replication



Replicates objects such as files, databases, or programs through software-based methods. The backup is a live version of the data object.

Hardware Replication

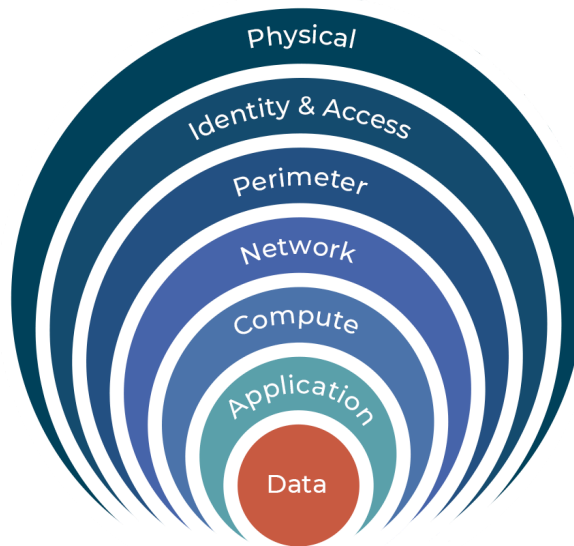


Implemented at the operating system or hardware level. Leverages the storage system's capability to take snapshots for synchronous copying.

Note: Backups, mirrors, clones, and snapshots can all be employed in either logical or hardware replication. The choice should consider the type of system and data and the level of resiliency required.

2. A Layered Security Approach: Defence-in-Depth

Defence-in-depth is a layered and step-wise approach to application protection for **protecting applications built in the cloud**. Each layer is an additional security measure. If a specific layer should be breached, the subsequent layers are already implemented to prevent further breaches.



The defence-in-depth approach with several security layers.

2.1. Physical Security

The actual security of buildings, controlled access to computing hardware, and ensuring that the correct people have access to physical components. This is the first line of defence.

2.2. Identity and Access Management

Managing who is allowed access to the system and infrastructure, and only granting them access to what is necessary. Logging ensures whoever accesses the system can be identified.

2.3. Perimeter

Protecting the network from unauthorised access using firewalls and advanced security methods to adapt to attacks and block unwanted traffic.

2.4. Network

Limiting connectivity across system resources to only what is necessary by: a) denying access by default; b) not allowing public internet access; and c) controlling incoming and outgoing traffic.

2.5. Compute

Ensuring compute resources are secure through restricting access and implementing endpoint protection such as anti-malware and anti-virus. Keeping operating systems up to date with the latest security patches.

2.6. Application

Security must be an integral part of application design from start to end, including penetration testing, using HTTPS/TLS for data in-transit, and ensuring passwords and sensitive information are stored securely.

2.7. Data

Access to data must be properly managed. Even if an attacker accesses the data, it should be unusable through data encryption, masking, and other techniques.

Conclusion

In this train, data security, its practices in big data applications, and the defence-in-depth approach were discussed. Robust data security solutions are not one-size-fits-all and should be specific to the use case, system, application, or data.

Appendix

[IBM 2020 Cost of a Data Breach Report](#)

[General Data Protection Regulation 2016/679 \(GDPR\)](#)

[Protection of Personal Information Act \(POPIA\)](#)

[ISO/IEC 27000 family of standards](#)

[Asymmetric vs Symmetric Encryption](#)

[NIST Guidelines for Media Sanitization](#)